



HackSimulator.nl

user@hacksimulator:~\$

Je Eerste Pentest

Stap-voor-Stap Playbook — Een praktisch werkboek voor beginnende ethische hackers

Versie 1.0 · april 2026

Over dit playbook

Je hebt geleerd wat Nmap doet. Je weet dat SQL injection bestaat. Je hebt misschien zelfs een paar challenges in HackSimulator afgerond. Maar dan komt de grote vraag: **hoe voer je een echte pentest uit, van begin tot eind?**

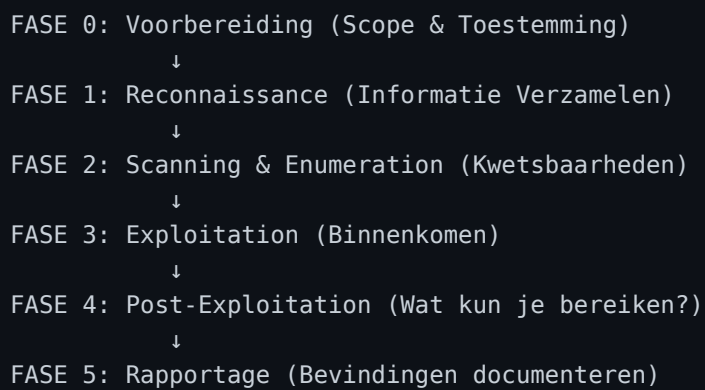
Dat is het verschil tussen tools kennen en een methodologie beheersen. Een timmerman die weet hoe een hamer werkt is nog geen huizenbouwer — daarvoor heb je een bouwplan nodig.

Dit playbook is dat bouwplan. Je leert niet welke knop je moet indrukken, maar **welke beslissingen je moet nemen, in welke volgorde, en waarom**. Na het doorwerken van dit playbook kun je een gestructureerde pentest opzetten, uitvoeren en rapporteren.

[!] Dit playbook is bedoeld voor gebruik op systemen waar je **schriftelijke toestemming** voor hebt. Zonder toestemming is elke techniek in dit boek illegaal. Zie de Juridische Gids van HackSimulator voor de volledige juridische achtergrond.

De 6 Fases van een Pentest

Elke professionele pentest volgt dezelfde structuur. Dit is geen willekeurige volgorde — elke fase bouwt voort op de vorige. Sla geen fases over.



```
graph TD; F0["FASE 0: Voorbereiding (Scope & Toestemming)"] --> F1["FASE 1: Reconnaissance (Informatie Verzamelen)"]; F1 --> F2["FASE 2: Scanning & Enumeration (Kwetsbaarheden)"]; F2 --> F3["FASE 3: Exploitation (Binnenkomen)"]; F3 --> F4["FASE 4: Post-Exploitation (Wat kun je bereiken?)"]; F4 --> F5["FASE 5: Rapportage (Bevindingen documenteren)"];
```

FASE 0: Voorbereiding (Scope & Toestemming)
↓
FASE 1: Reconnaissance (Informatie Verzamelen)
↓
FASE 2: Scanning & Enumeration (Kwetsbaarheden)
↓
FASE 3: Exploitation (Binnenkomen)
↓
FASE 4: Post-Exploitation (Wat kun je bereiken?)
↓
FASE 5: Rapportage (Bevindingen documenteren)

Fase 0: Voorbereiding — Voordat Je Begint

Dit is de fase die beginners overslaan en professionals nooit vergeten. Zonder goede voorbereiding heb je geen bewijs van toestemming, geen duidelijke scope, en geen plan.

Het toestemmingsdocument

Voordat je ook maar één command typt, moet je dit op papier hebben:

Onderdeel	Wat erin staat	Voorbeeld
Wie	Opdrachtgever + tester	"SecureCorp BV, pentest door [jouw naam]"
Wat	Welke systemen (scope)	"Webapplicatie op app.securecorp.nl + API"
Wat NIET	Expliciet buiten scope	"Productiedatabase mag niet gewijzigd worden"
Wanneer	Start- en einddatum	"1-15 april 2026, werkdagen 09:00-18:00"
Hoe	Toegestane technieken	"Port scanning, web app testing, brute force op test-accounts"
Contact	Wie bel je bij problemen?	"Jan de Vries, CISO, 06-12345678"
Data	Wat doe je met gevonden gegevens?	"Versleuteld opgeslagen, na rapport verwijderd"

[!] Geen document = geen pentest. "Ze zeiden dat het mocht" is geen bewijs. Schriftelijk, ondertekend, bewaard.

Je testomgeving

Zorg dat je het volgende hebt:

- ☐ Eigen laptop/VM (niet het netwerk van je werkgever of school)
- ☐ VPN-verbinding als je op afstand test
- ☐ Logging aan — alles wat je doet wordt vastgelegd (beschermt jou)
- ☐ Screenshot-tool klaar (bewijs van bevindingen)
- ☐ Notitieboek/document open voor aantekeningen
- ☐ Contactgegevens van opdrachtgever bij de hand

Mentale checklist

Stel jezelf drie vragen:

1. **Heb ik toestemming voor wat ik ga doen?** → Zo niet: stop.
2. **Weet ik wat de scope is?** → Zo niet: vraag verduidelijking.

3. **Weet ik wie ik moet bellen als er iets misgaat?** → Zo niet: regel het eerst.

Fase 1: Reconnaissance — Het Doelwit Verkennen

Doel: Zoveel mogelijk informatie verzamelen ZONDER het doelwit direct aan te raken.

Reconnaissance is de fase die het verschil maakt tussen een amateur en een professional. Hoe meer je weet voordat je begint met scannen, hoe gericht(er) en stiller je kunt werken.

Passieve reconnaissance (geen direct contact)

Dit zijn technieken waarbij het doelwit niet merkt dat je bezig bent.

WHOIS — Wie is de eigenaar?

```
whois securecorp.nl
```

Wat je zoekt:

- Registrant naam en organisatie → wie beheert het domein?
- Nameservers → welke DNS provider? (bijv. Cloudflare = extra beveiliging)
- Aanmaakdatum → oud domein = meer historie om te onderzoeken
- E-mailadressen → bruikbaar voor social engineering of als login-naam

DNS records — Welke systemen bestaan er?

```
dig securecorp.nl ANY
```

[LET OP] `dig` is een standaard Linux-tool voor DNS-lookups. Dit command is niet beschikbaar in HackSimulator, maar wel op elk Linux-systeem en in TryHackMe-omgevingen.

Wat je zoekt:

- A-records → IP-adressen van servers
- MX-records → mailservers (vaak andere leverancier)
- TXT-records → SPF/DKIM configuratie, soms interne info
- Subdomains → `dev.securecorp.nl`, `staging.securecorp.nl`

Openbare bronnen:

- Google dorking: `site:securecorp.nl filetype:pdf` → openbare documenten
- LinkedIn: welke technologieën gebruiken hun developers? (vacatures zijn goudmijnen)
- GitHub: heeft het bedrijf openbare repositories? Staan er secrets in commits?
- Shodan.io: welke services zijn publiek zichtbaar?

Actieve reconnaissance (direct contact)

Nu ga je het doelwit wél aanraken. Vanaf hier moet je toestemming hebben.

Ping — Is het doelwit bereikbaar?

```
ping 192.168.1.100
```

[TIP] Geen ping-antwoord betekent niet altijd “offline.” Veel firewalls blokkeren ICMP (het netwerkprotocol achter ping). Gebruik nmap met de `-Pn` flag om toch te scannen.

Traceroute — Hoe ziet het netwerk eruit?

```
traceroute 192.168.1.100
```

Wat je zoekt:

- Aantal hops → hoe ver weg is het doelwit?
- Timeouts (* * *) → mogelijk een firewall die verkeer filtert
- Onverwachte tussenstops → proxy's, load balancers

Wat je nu moet hebben

Na Fase 1 heb je een “target profile”:

```
┌ TARGET PROFILE ────────────┐
│ Domein: securecorp.nl       │
│ IP: 192.168.1.100           │
│ Online: Ja (ping bevestigd)  │
│ DNS: Cloudflare (DDoS protection) │
│ Subdomains: app., api., dev., staging. │
│ Tech stack: nginx, mogelijk PHP/Node.js │
│ Mail: Google Workspace (MX records) │
│ Contactpersonen: 3 developers op LinkedIn │
└────────────────────────────────┘
```

Fase 2: Scanning & Enumeration — Kwetsbaarheden Zoeken

Doel: Systematisch ontdekken welke services draaien, welke versies, en welke kwetsbaarheden er zijn.

Port scanning met Nmap

```
nmap 192.168.1.100
```

De output interpreteren:

PORT	STATE	SERVICE	Wat betekent dit?
22/tcp	OPEN	SSH	→ Remote toegang mogelijk
80/tcp	OPEN	HTTP	→ Webserver (onversleuteld!)
443/tcp	OPEN	HTTPS	→ Webserver (versleuteld)
3306/tcp	OPEN	MySQL	→ Database PUBLIEK bereikbaar!
8080/tcp	FILTERED	HTTP-Alt	→ Firewall blokkeert deze poort

Beslisboom na port scan:

```
Welke poorten zijn open? —
|
| Poort 22 (SSH) open?
|   → Check: default credentials? Zwak wachtwoord?
|
| Poort 80/443 (HTTP/HTTPS) open?
|   → Webapplicatie! Ga door met Nikto.
|
| Poort 3306 (MySQL) of 5432 (PostgreSQL) open?
|   → RODE VLAG! Database publiek bereikbaar.
|   → Noteer als HIGH severity finding.
|
| Poort 21 (FTP) open?
|   → Check: anonymous login mogelijk?
|
| Poort 8080 open?
|   → Vaak development/admin interface.
```

Web vulnerability scanning met Nikto

Als je een webserver hebt gevonden (poort 80 of 443):

```
nikto http://192.168.1.100
```

Nikto vindt...	Ernst	Wat je doet
----------------	-------	-------------

<code>/admin/</code> bereikbaar	HOOG	Noteer. Probeer default credentials.
<code>/.git/</code> exposed	KRITIEK	Broncode + history downloadbaar.
<code>phpinfo.php</code> aanwezig	MEDIUM	Information disclosure.
Verouderde server versie	MEDIUM-HOOG	Zoek naar bekende CVE's (openbaar gedocumenteerde kwetsbaarheden).
Ontbrekende security headers	LAAG-MEDIUM	Noteer welke ontbreken (CSP, HSTS).
<code>/backup/</code> of <code>.sql</code> bestanden	KRITIEK	Mogelijk database dumps of credentials.
Directory indexing aan	MEDIUM	Mappen zijn browsable.

SQL injection testen met SQLmap

Als je URL-parameters hebt gevonden (bijv. `?id=1`):

```
sqlmap http://192.168.1.100/products?id=1
```

Hoe SQL injection werkt:

Een normale query:

```
SELECT * FROM products WHERE id = 1;
→ Geeft product #1 terug. Normaal.
```

Een geïnjekteerde query:

```
SELECT * FROM products WHERE id = 1' OR '1'='1;
→ '1'='1' is ALTIJD waar → geeft ALLE producten terug!
```

[!] PROPORTIONALITEIT: Bewijs dat SQL injection mogelijk is. Download niet de hele database. Eén tabel-naam of één rij is genoeg bewijs. Meer dan dat is disproportioneel en mogelijk strafbaar — zelfs met toestemming.

Wat je nu moet hebben

Na Fase 2 heb je een vulnerability map:

```
VULNERABILITY MAP
KRITIEK:
• SQL injection op /products?id= (error-based)
• .git/ exposed → broncode + credentials leesbaar
• MySQL (3306) publiek bereikbaar
```

H00G:

- /admin/ panel met standaard login (admin:admin)
- SSH met zwak wachtwoord (geen rate limiting)

MEDIUM:

- Verouderde nginx versie (1.18, huidige: 1.28)
- Ontbrekende security headers (CSP, HSTS)

LAAG:

- HTTP → HTTPS redirect ontbreekt

Fase 3: Exploitation — Binnenkomen

Doel: Bewijzen dat de gevonden kwetsbaarheden daadwerkelijk uitbuitbaar zijn.

[LET OP] Dit is de fase waar proportionaliteit het belangrijkste is. Je doel is bewijzen dat het KAN, niet alles kapotmaken. Eén geslaagde login is bewijs genoeg. Stop zodra je je punt hebt gemaakt.

Brute force met Hydra

Als je een login-service hebt gevonden (SSH, FTP, webformulier):

```
hydra ssh://192.168.1.100
```

Situatie	Kans	Waarom
Default credentials (admin:admin)	HOOG	Veel systemen veranderen defaults nooit
Geen rate limiting	HOOG	Honderden pogingen per seconde mogelijk
Korte wachtwoorden (<8 tekens)	MEDIUM	Beperkt aantal combinaties
Sterk wachtwoord + rate limiting + 2FA	ZEER LAAG	Meerdere verdedigingslagen

Exploitation met Metasploit

Als je verouderde software hebt gevonden met bekende kwetsbaarheden:

```
metasploit 192.168.1.100
```

Waarom bekende kwetsbaarheden zo gevaarlijk zijn:

De meeste succesvolle aanvallen gebruiken BEKENDE kwetsbaarheden waarvoor al patches beschikbaar zijn:

Exploit	CVE	Gevolg	Patch beschikbaar?
EternalBlue	MS17-010	WannaCry ransomware, 200.000+ systemen	Ja, 2 maanden eerder
Log4Shell	CVE-2021-44228	Miljoenen Java-apps kwetsbaar	Ja, patch binnen dagen
BlueKeep	CVE-2019-0708	Windows RDP, 1 miljoen+ systemen	Ja, maanden eerder

[TIP] Het probleem is bijna nooit dat er geen patch is. Het probleem is dat organisaties niet snel genoeg patchen.

Fase 4: Post-Exploitation — Hoe Diep Gaat Het?

Doel: Bepalen wat een aanvaller zou kunnen bereiken na initiële toegang.

[LET OP] Je bent nog steeds gebonden aan de scope. Als het toestemmingsdocument zegt “alleen de webapplicatie,” dan ga je niet door naar de database server — ook al kun je erbij.

Systeem verkennen

Gebruikers bekijken:

```
cat /etc/passwd
```

Waar je op let:

- Accounts met `/bin/bash` als shell → kunnen inloggen
- Accounts met UID 0 → hebben root-rechten
- Service accounts → onverwachte accounts kunnen backdoors zijn

Netwerk bekijken:

```
ifconfig  
netstat
```

Waar je op let:

- Interne IP-ranges → welke andere systemen zijn bereikbaar?
- Actieve verbindingen → praat dit systeem met databases, andere servers?

Gevoelige data zoeken

Password hashes:

```
cat /etc/shadow
```

Configuratiebestanden:

```
cat config.php  
cat .env
```

Command history:

```
cat ~/.bash_history
```

Wat je vindt	Ernst
Database credentials in plain text	KRITIEK
API keys	HOOG
Debug mode aan in productie	MEDIUM

Wachtwoorden in bash history	KRITIEK
SSH verbindingen naar andere servers	Laterale beweging mogelijk

Password cracking met Hashcat

Als je password hashes hebt gevonden:

```
hashcat [hash]
```

Begin met...	Type	Veiligheid
\$1\$	MD5	ONVEILIG — seconden
\$5\$	SHA-256	MATIG — uren tot dagen
\$6\$	SHA-512	REDELIJK — dagen tot weken
\$y\$	yescrypt	GOED — standaard op moderne Linux
\$2b\$	bcrypt	GOED — maanden tot jaren
\$argon2	Argon2	BESTE — jaren tot onmogelijk

Fase 5: Rapportage — Je Bevindingen Opschrijven

Doel: Een helder, bruikbaar rapport dat de opdrachtgever helpt om hun beveiliging te verbeteren.

Dit is de fase die beginners onderschatten. Een briljante pentest zonder goed rapport is waardeloos.

Rapport structuur

PENTEST RAPPORT

1. MANAGEMENT SAMENVATTING (1 pagina)
Voor: directie, management
2. SCOPE & METHODE (1 pagina)
Wat is getest, wanneer, met welke tools
3. BEVINDINGEN (kern van het rapport)
Per finding: beschrijving, ernst, bewijs
4. POSITIEVE BEVINDINGEN
Wat was goed?
5. AANBEVELINGEN (geprioriteerd)
6. BIJLAGEN
Tool output, screenshots, technische details

Ernst-classificatie (CVSS-gebaseerd)

CVSS (Common Vulnerability Scoring System) is de internationale standaard om de ernst van een kwetsbaarheid te scoren op een schaal van 0 tot 10. Vertaald naar begrijpelijke categorieën:

Ernst	Kleur	Voorbeeld	Actie
KRITIEK	Rood	SQL injection met data-extractie	Binnen 24 uur
HOOG	Oranje	SSH met default credentials	Binnen 1 week
MEDIUM	Geel	Verouderde software versie	Binnen 1 maand
LAAG	Groen	Ontbrekende security headers	Bij volgende update
INFO	Blauw	Server versie zichtbaar	Overweeg te verbergen

Een finding beschrijven — het template

Elke finding volgt dit format:

```
FINDING #1

Titel: SQL Injection in productpagina
Ernst: KRITIEK
Locatie: https://app.securecorp.nl/products?id=1

BESCHRIJVING:
De parameter 'id' is kwetsbaar voor SQL injection.

IMPACT:
• Alle klantgegevens uitlezen
• Wachtwoord hashes ophalen
• Data wijzigen of verwijderen

BEWIJS:
URL: /products?id=1' OR '1'='1
Resultaat: alle 847 producten (normaal: 1)

AANBEVELING:
1. Prepared statements implementeren
2. Input validation (alleen integers)
3. Database-gebruikersrechten beperken

REFERENTIE:
• OWASP A05:2025 – Injection
• CWE-89: SQL Injection
```

Positieve bevindingen niet vergeten

POSITIEVE BEVINDINGEN:

- ✓ HTTPS correct geconfigureerd
- ✓ Rate limiting actief op login formulier
- ✓ Database backups versleuteld opgeslagen
- ✓ 2FA actief voor admin accounts
- ✓ Firewall blokkeert onnodige poorten

[TIP] Positieve bevindingen zijn niet alleen beleefd — ze laten zien dat je grondig bent geweest en helpen het team te zien waar hun investering wél werkt.

Management samenvatting schrijven

De management samenvatting is vaak het enige deel dat de directie leest.

> In de periode [datum] tot [datum] is een penetration test uitgevoerd op [systeem]. Tijdens deze test zijn **[X] kwetsbaarheden** gevonden, waarvan **[X] kritiek**, **[X] hoog**, **[X] medium** en **[X] laag**. > > De belangrijkste risico's zijn: [Kritieke finding in één zin]. Bij ongewijzigd beleid kan een aanvaller [concrete impact]. > > Aanbeveling: prioriteer de kritieke en hoge bevindingen. Een follow-up scan na herstel wordt aanbevolen.

Snelreferentie: Alle Commands

Reconnaissance

Command	Doel	Voorbeeld
ping	Host bereikbaarheid testen	ping 192.168.1.100
tracert	Netwerkp pad in kaart brengen	tracert 192.168.1.100
whois	Domein-eigenaar opzoeken	whois securecorp.nl
dig	DNS records opvragen	dig securecorp.nl ANY

Scanning

Command	Doel	Voorbeeld
nmap	Open poorten ontdekken	nmap 192.168.1.100
nikto	Web kwetsbaarheden scannen	nikto http://192.168.1.100
sqlmap	SQL injection testen	sqlmap http://target/page?id=1

Exploitation

Command	Doel	Voorbeeld
hydra	Brute force login	hydra ssh://192.168.1.100
metasploit	Exploit framework	metasploit 192.168.1.100
hashcat	Password hashes kraken	hashcat [hash]

Veelvoorkomende poorten

Poort	Service	Risico bij open
21	FTP	Verouderd protocol, vaak onveilig
22	SSH	Brute force als wachtwoord zwak is
23	Telnet	ZEER onveilig (plain text!)

25	SMTP	Open relay = spam
80	HTTP	Webserver (onversleuteld)
443	HTTPS	Webserver (versleuteld)
3306	MySQL	Database direct bereikbaar = FOUT
5432	PostgreSQL	Database direct bereikbaar = FOUT
8080	HTTP-Alt	Vaak dev/admin interfaces

Hoe Nu Verder?

Dit playbook geeft je de structuur. Om de vaardigheden te oefenen:

1. **HackSimulator.nl** — Oefen alle commands in een veilige omgeving
2. **TryHackMe** — “Cyber Security 101” learning path (Engels, gratis tier)
3. **picoCTF** — Gratis CTF competitie voor beginners (jaarlijks, Carnegie Mellon University)
4. **HackTheBox** — Wanneer je klaar bent voor echte uitdagingen

[TIP] De beste pentesters zijn niet degenen die de meeste tools kennen — het zijn degenen die de beste vragen stellen en het scherpst nadenken over wat ze zien.

*Dit playbook is geschreven voor HackSimulator.nl — de gratis browser-based terminal simulator voor ethisch hacken.
Versie 1.0 · Met zorg samengesteld en gecontroleerd · april 2026*